클라우드 보안 진단 리포트

1. 진단 요약

- 전체 점검 수: 33
- 양호 항목 수: 21
- 취약 항목 수: 11
- 보안 점수: 65
- 종합 의견: 현재 클라우드 환경은 전반적으로 양호한 보안 상태를 유지하고 있으나, 일부 중요 보안 설정에 대한 개선이 필요합니다. 특히, 관리자 계정의 권한 관리 및 MFA 설정 강화, 그리고 CloudTrail 로그 암호화 적용을 통해 보안 수준을 더욱 높일 수 있습니다.

2. 우선 조치 대상

위험도와 영향도를 기준으로 우선 조치해야 할 항목을 정리합니다.

- **루트 계정 MFA 미설정 (위험도: 상)**: 계정 탈취 시 심각한 영향을 줄 수 있으므로 최우선 조치가 필요합니다.
- **IAM 사용자 MFA 미설정 (admin, test2, test3) (위험도: 상)**: 관리자 계정의 보안을 강화하여 무단 접근을 방지해야 합니다.
- **IAM Admin User (admin, test1, test2, test3) (위험도: 상)**: 최고 관리자 권한을 가진 계정의 수를 줄이고, 업무에 필요한 최소한의 권한만 부여해야 합니다.
- **Security Group SSH Open (launch-wizard-2) (위험도: 상)**: SSH 포트가 전체 개방되어 있어 외부 공격에 노출될 위험이 있습니다.
- **Security Group RDP Open (launch-wizard-2) (위험도: 상)**: RDP 포트가 전체 개방되어 있어 외부 공격에 노출될 위험이 있습니다.
- **CloudTrail Log Encryption (management-events) (위험도: 중)**: 로그 데이터의 기밀성을 보장하기 위해 암호화 설정이 필요합니다.

3. 상세 취약점 분석

루트 계정 MFA 미설정

점검 항목

- 진단 항목: Root Account MFA Enabled
- 대상: Root Account
- 위험도: 상
- KISA 코드: KISA-CLD-08
- SK쉴더스 가이드 항목: 1.9 MFA 설정

원인 분석

루트 계정에 다중 인증(MFA)이 설정되어 있지 않아, 비밀번호만으로 접근이 가능하여 계정 탈취 위험이 존재합니다.

보안 영향

루트 계정은 모든 AWS 리소스에 대한 최고 권한을 가지므로, 해당 계정이 탈취될 경우 심각한 보안 사고로 이어질 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정에도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM 사용자 MFA 미설정 (admin)

점검 항목

- 진단 항목: IAM User MFA Enabled
- 대상: admin
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK쉴더스 가이드 항목: 1.9 MFA 설정

원인 분석

'admin' IAM 사용자 계정에 다중 인증(MFA)이 설정되어 있지 않아, 비밀번호만으로 접근이 가능하여 계정 탈취 위험이 존재합니다.

보안 영향

관리자 권한을 가진 계정이 탈취될 경우, 해당 계정으로 수행 가능한 모든 작업이 무단으로 이루어질 수 있어 심각한 보안 위협이 발생할 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정에도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM 사용자 MFA 미설정 (test2)

점검 항목

- 진단 항목: IAM User MFA Enabled
- 대상: test2
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK쉴더스 가이드 항목: 1.9 MFA 설정

원인 분석

'test2' IAM 사용자 계정에 다중 인증(MFA)이 설정되어 있지 않아, 비밀번호만으로 접근이 가능하여 계정 탈취 위험이 존재합니다.

보안 영향

관리자 권한을 가진 계정이 탈취될 경우, 해당 계정으로 수행 가능한 모든 작업이 무단으로 이루어질 수 있어 심각한 보안 위협이 발생할 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정에도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM 사용자 MFA 미설정 (test3)

점검 항목

- 진단 항목: IAM User MFA Enabled

- 대상: test3
- 위험도: 상
- KISA 코드: KISA-CLD-02
- SK쉴더스 가이드 항목: 1.9 MFA 설정

원인 분석

'test3' IAM 사용자 계정에 다중 인증(MFA)이 설정되어 있지 않아, 비밀번호만으로 접근이 가능하여 계정 탈취 위험이 존재합니다.

보안 영향

관리자 권한을 가진 계정이 탈취될 경우, 해당 계정으로 수행 가능한 모든 작업이 무단으로 이루어질 수 있어 심각한 보안 위협이 발생할 수 있습니다.

단계별 조치 가이드

1. IAM 콘솔에서 사용자 또는 루트 계정의 보안 자격 증명 메뉴로 이동합니다.
2. 멀티 팩터 인증 장치 할당을 선택합니다.
3. 가상 MFA 앱 또는 보안 키를 등록합니다.
4. 등록된 MFA 장치가 정상 동작하는지 확인합니다.
5. 관리자 계정과 중요 계정에 우선 적용합니다.

조치 후 확인 방법

1. IAM 사용자별 MFA 장치가 연결되어 있는지 확인합니다.
2. Root 계정에도 MFA가 활성화되어 있는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.9 MFA 설정

IAM Admin User (admin)

점검 항목

- 진단 항목: IAM Admin User
- 대상: admin

- 위험도: 상
- KISA 코드: KISA-CLD-12
- SK쉴더스 가이드 항목: 1.7 Admin Console 관리자 정책 관리

원인 분석

'admin' 사용자는 모든 AWS 서비스에 접근할 수 있는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다. 해당 계정이 탈취되거나 오용될 경우, 시스템 전체에 심각한 영향을 미칠 수 있습니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

IAM Admin User (test1)

점검 항목

- 진단 항목: IAM Admin User
- 대상: test1
- 위험도: 상

- KISA 코드: KISA-CLD-12
- SK쉴더스 가이드 항목: 1.7 Admin Console 관리자 정책 관리

원인 분석

'test1' 사용자는 모든 AWS 서비스에 접근할 수 있는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다. 해당 계정이 탈취되거나 오용될 경우, 시스템 전체에 심각한 영향을 미칠 수 있습니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

IAM Admin User (test2)

점검 항목

- 진단 항목: IAM Admin User
- 대상: test2
- 위험도: 상
- KISA 코드: KISA-CLD-12

- SK쉴더스 가이드 항목: 1.7 Admin Console 관리자 정책 관리

원인 분석

'test2' 사용자는 모든 AWS 서비스에 접근할 수 있는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다. 해당 계정이 탈취되거나 오용될 경우, 시스템 전체에 심각한 영향을 미칠 수 있습니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

IAM Admin User (test3)

점검 항목

- 진단 항목: IAM Admin User
- 대상: test3
- 위험도: 상
- KISA 코드: KISA-CLD-12
- SK쉴더스 가이드 항목: 1.7 Admin Console 관리자 정책 관리

원인 분석

'test3' 사용자는 모든 AWS 서비스에 접근할 수 있는 AdministratorAccess 권한을 가지고 있습니다.

보안 영향

최고 관리자 권한을 가진 계정은 모든 AWS 서비스에 접근할 수 있으므로, 일상적인 서비스 운영 용도로 사용하는 것은 위험합니다. 해당 계정이 탈취되거나 오용될 경우, 시스템 전체에 심각한 영향을 미칠 수 있습니다.

단계별 조치 가이드

1. IAM 사용자 및 정책 목록을 확인합니다.
2. AdministratorAccess 정책이 부여된 계정을 식별합니다.
3. 업무상 최고 권한이 필요한 계정인지 검토합니다.
4. 불필요한 관리자 권한을 제거합니다.
5. 업무 역할에 맞는 최소 권한 정책으로 변경합니다.

조치 후 확인 방법

1. 불필요한 AdministratorAccess 정책이 제거되었는지 확인합니다.
2. 관리자 권한 계정이 최소한으로 유지되는지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 1.7 Admin Console 관리자 정책 관리

Security Group SSH Open (launch-wizard-2)

점검 항목

- 진단 항목: Security Group SSH Open
- 대상: launch-wizard-2 (sg-0505ccf9abb1ac83e)
- 위험도: 상
- KISA 코드: KISA-CLD-03
- SK쉴더스 가이드 항목: 3.1 보안 그룹 인/아웃바운드 ANY 설정 관리

원인 분석

'launch-wizard-2' 보안 그룹에서 SSH(22번 포트)가 모든 IP 주소(0.0.0.0/0)에서 접근 가능하도록 설정되어 있습니다.

보안 영향

SSH 포트가 전체 개방되어 있으면 외부에서 무차별 대입 공격(Brute-force attack)이나 악성코드 감염을 통한 침입 시도가 용이해져, 서버에 대한 무단 접근 및 데이터 유출의 위험이 높아집니다.

단계별 조치 가이드

1. EC2 콘솔에서 보안 그룹 목록을 확인합니다.
2. 인바운드 및 아웃바운드 규칙을 검토합니다.
3. 0.0.0.0/0 또는 ::/0으로 전체 포트가 허용된 규칙을 식별합니다.
4. 불필요한 ANY 허용 규칙을 삭제합니다.
5. 업무에 필요한 포트와 IP 대역만 허용합니다.

조치 후 확인 방법

1. 보안 그룹에 전체 포트 전체 대역 허용 규칙이 없는지 확인합니다.
2. SSH, RDP 등 관리 포트가 제한된 IP에서만 접근 가능한지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 3.1 보안 그룹 인/아웃바운드 ANY 설정 관리

Security Group RDP Open (launch-wizard-2)

점검 항목

- 진단 항목: Security Group RDP Open
- 대상: launch-wizard-2 (sg-0505ccf9abb1ac83e)
- 위험도: 상
- KISA 코드: KISA-CLD-07
- SK쉴더스 가이드 항목: 3.1 보안 그룹 인/아웃바운드 ANY 설정 관리

원인 분석

'launch-wizard-2' 보안 그룹에서 RDP(3389번 포트)가 모든 IP 주소(0.0.0.0/0)에서 접근 가능하도록 설정되어 있습니다.

보안 영향

RDP 포트가 전체 개방되어 있으면 외부에서 무차별 대입 공격(Brute-force attack)이나 악성코드 감염을 통한 침입 시도가 용이해져, 서버에 대한 무단 접근 및 데이터 유출의 위험이 높아집니다.

단계별 조치 가이드

1. EC2 콘솔에서 보안 그룹 목록을 확인합니다.
2. 인바운드 및 아웃바운드 규칙을 검토합니다.
3. 0.0.0.0/0 또는 ::/0으로 전체 포트가 허용된 규칙을 식별합니다.
4. 불필요한 ANY 허용 규칙을 삭제합니다.
5. 업무에 필요한 포트와 IP 대역만 허용합니다.

조치 후 확인 방법

1. 보안 그룹에 전체 포트 전체 대역 허용 규칙이 없는지 확인합니다.
2. SSH, RDP 등 관리 포트가 제한된 IP에서만 접근 가능한지 확인합니다.

근거 출처

- 문서: SK쉴더스 2024 클라우드 보안 가이드 AWS
- 항목: 3.1 보안 그룹 인/아웃바운드 ANY 설정 관리

CloudTrail Log Encryption

점검 항목

- 진단 항목: CloudTrail Log Encryption
- 대상: management-events
- 위험도: 중
- KISA 코드: KISA-CLD-10
- SK쉴더스 가이드 항목: 제공된 가이드 기준으로는 추가 확인이 필요합니다.

원인 분석

'management-events' 트레일에서 로그 암호화(KMS) 설정이 되어 있지 않습니다.

보안 영향

CloudTrail 로그가 암호화되지 않으면, 저장된 로그 데이터가 외부에 노출될 경우 민감한 정보가 유출될 위험이 있습니다.

단계별 조치 가이드

제공된 가이드 기준으로는 추가 확인이 필요합니다.

조치 후 확인 방법

제공된 가이드 기준으로는 추가 확인이 필요합니다.

근거 출처

- 문서: 제공된 가이드 기준으로는 추가 확인이 필요합니다.
- 항목: 제공된 가이드 기준으로는 추가 확인이 필요합니다.